

Dieses Handbuch erkl rt ISCY fachlich und in einfacher Sprache. Es ist fuer Menschen geschrieben, die nicht aus einem ISMS-, Compliance- oder Informationssicherheits-Umfeld kommen.

ISCY ist eine selbst gehostete, lokale und datenschutzbewusste Open-Source-Plattform unter AGPL-3.0-only. Die Rust-/Axum-Anwendung wird aktiv entwickelt und befindet sich in einer fruehen Community-Adoptionsphase; Schnittstellen, Datenmodelle und Betriebsverfahren koennen sich weiterentwickeln.

ISCY wurde in dieser Codebasis mit Unterstuetzung von OpenAI Codex entwickelt, nach Rust migriert und technisch/fachlich plausibilisiert. Die fachliche Ausrichtung wurde mit offiziellen EU-Quellen zu NIS2, der NIS2-Durchfuehrungsverordnung (EU) 2024/2690, DORA, Cyber Resilience Act und EU AI Act sowie mit gaengigen ISMS-, Product-Security-, CVE-/SBOM-/CSAF-, Evidence- und Incident-Response-Praktiken abgeglichen. Das ist keine unabhaengige fachliche Pruefung, externe Zertifizierung oder Rechtsberatung. Regulatorische Unterstuetzung muss fuer Organisation, Rechtsraum und Einsatzkontext eigenstaendig bewertet werden.

1. Was ISCY ist:

ISCY ist eine Arbeitsplattform fuer:

- den Aufbau und die Pflege eines ISMS nach ISO 27001
- die Einordnung regulatorischer Anforderungen wie NIS2 und KRITIS
- die Planung, Bewertung und Nachverfolgung von Risiken
- die Dokumentation von Nachweisen, Audits und Management Reviews
- die strukturierte Bearbeitung von Produkt- und Software-Sicherheitsfragen
- die Bewertung von Schwachstellen und CVEs mit lokalem LLM-Enrichment
- die Auswertung von Zero-Trust-Agent-Posture fuer Windows, macOS und Linux

ISCY ist damit kein reines Ticketsystem und kein reines DMS. Es verbindet Governance, Nachweise, Risiken, Umsetzungsplanung und Produkt-Sicherheit in einem gemeinsamen Arbeitsmodell.

2. Grundprinzipien in einfacher Sprache:

2.1 Tenant:

Ein Tenant ist in ISCY die organisatorische Einheit, fuer die gearbeitet wird. Das kann zum Beispiel sein:

- ein Unternehmen
- eine Gesellschaft
- eine Business-Plattform
- ein Mandant in einer Beratungs- oder Gruppenstruktur

Fast alle Daten in ISCY gehoeren zu genau einem Tenant. Dadurch bleiben Daten voneinander getrennt.

2.2 Assessment Session:

Eine Assessment Session ist ein strukturierter Bewertungsdurchlauf. In ihr werden Profil, Scope, regulatorische Betroffenheit, Reifegrad und Ergebnisse zusammengefasst.

2.3 Requirement:

Ein Requirement ist eine Anforderung. Das kann eine ISO-27001-Anforderung, eine NIS2-bezogene Pflicht oder eine interne Vorgabe sein.

2.4 Evidence:

Evidence ist ein Nachweis. Zum Beispiel:

- eine Richtlinie
- ein Screenshot
- ein Auditprotokoll
- eine Verfahrensanweisung
- ein Export aus einem Drittsystem

2.5 Risk:

Ein Risk beschreibt ein moegliches negatives Ereignis fuer das Unternehmen. In ISCY wird ein Risiko ueber Auswirkung und Eintrittswahrscheinlichkeit bewertet.

2.6 Roadmap:

Die Roadmap uebersetzt Analyseergebnisse in konkrete Umsetzungsarbeit. Sie beantwortet die Frage: Was tun wir wann und warum?

2.7 CVE:

Eine CVE ist eine bekannte Schwachstelle mit standardisierter Kennung, zum Beispiel CVE-2026-12345.

2.8 Zero-Trust Agent:

Der Zero-Trust Agent ist ein read-only Collector. Er meldet Inventar, Heartbeats und Posture-Findings an ISCY. Produktive Agenten koennen mit Enrollment-Token aufgenommen werden und melden danach mit einem Agent-Secret, optional gebunden an einen mTLS-Client-Zertifikat-Fingerprint. Daraus entstehen keine automatischen Systemaenderungen, sondern nachvollziehbare Sichtbarkeit fuer Assets, Risiken, Evidenzen und Roadmap-Arbeit.

3. Wie man ISCY fachlich lesen sollte:

ISCY folgt fachlich einem roten Faden:

1. Organisation verstehen
2. Scope und Relevanz bestimmen
3. Anforderungen und Reifegrad bewerten
4. Risiken ableiten
5. Nachweise sammeln
6. Massnahmen planen
7. Audits, Reviews und Reports durchfuehren
8. Produkt- und Schwachstellen-Themen integrieren

4. Navigation und Funktionsbereiche:

Die wichtigsten Bereiche sind:

- Start-Wizard unter /
- Guidance Navigator unter /navigator/
- Dashboard unter /dashboard/
- Zero Trust unter /zero-trust/
- Catalog unter /catalog/
- Reports unter /reports/
- Roadmap unter /roadmap/
- Evidence unter /evidence/
- Assets unter /assets/
- Suppliers unter /suppliers/
- Imports unter /imports/
- Processes unter /processes/
- AI Governance unter /ai-governance/
- Requirements unter /requirements/
- Risks unter /risks/
- Assessments unter /assessments/
- Organizations unter /organizations/
- Product Security unter /product-security/
- Vulnerability Intelligence unter /cves/

5. Fachliche Erklaerung aller Hauptfunktionen:

5.1 Organizations:

Zweck:

Die Stammdaten des Mandanten erfassen.

Was hier gepflegt wird:

- Name und Identitaet des Unternehmens oder Mandanten
- Land und Einsatzlaender
- Sektor

- Groessenindikatoren wie Mitarbeitendenzahl und Umsatz
- kritische Dienstleistungen
- Relevanz fuer NIS2 oder KRITIS
- DORA-Rolle, also Finanzunternehmen oder IKT-Drittdienstleister
- DSGVO-Rolle, also Verantwortlicher, Auftragsverarbeiter und besondere Datenkategorien
- CRA-Relevanz fuer digitale Produkte
- AI-Act-Profil und Hochrisiko-Hinweis
- TISAX-Scope und ISO-27001-Zielbild
- regulatorische Notizen fuer Scope- und Managemententscheidungen
- Product-Security-Kontext

Fachlicher Nutzen:

- Grundlage fuer regulatorische Einordnung
- Grundlage fuer spaetere Berichte und Filter
- Entscheidungshilfe fuer NIS2-/KRITIS-Betroffenheit
- zentrale Vorsteuerung fuer DORA, DSGVO, CRA, AI Act, TISAX und ISO-27001-Arbeit

Technischer Stand:

Schreibberechtigte Nutzer koennen dieses Profil direkt in /organizations/ pflegen. Die Seite zeigt eine regulatorische Matrix mit aktiven Pfaden, Begrueendung und naechsten fachlichen Schritten. Die API stellt dasselbe Profil ueber GET und PATCH /api/v1/organizations/tenant-profile bereit.

Fuer Nicht-Sicherheitsleute:

Dies ist die Stammdatenakte des Unternehmens in ISCY.

5.2 Wizard:

Zweck:

Den Nutzer Schritt fuer Schritt durch eine Erst- oder Wiederbewertung fuehren.

Schritte:

- Start
- Profil
- Applicability
- Scope
- Maturity
- Results

Fachlicher Nutzen:

- strukturiertes Onboarding in das Thema
- erste regulatorische Einordnung
- erste Reifegrad-Sicht
- Grundlage fuer Reports und Roadmap

Fuer Nicht-Sicherheitsleute:

Der Wizard ist der gefuehrte Fragebogen, der aus Eingaben verwertbare Ergebnisse macht.

5.3 Guidance Navigator:

Zweck:

Orientierung geben, welche fachlichen Schritte als naechstes sinnvoll sind.

Typische Inhalte:

- Arbeitspakete
- empfohlene Reihenfolge
- Status der Bearbeitung
- Detailseiten zu einzelnen Schritten

Fachlicher Nutzen:

- priorisierte Navigation
- weniger Leerlauf und weniger doppelte Arbeit
- bessere Anschlussfaehigkeit fuer neue Nutzer

Fuer Nicht-Sicherheitsleute:

Das ist die fachliche Landkarte durch das System.

5.4 Dashboard:

Zweck:

Management-taugliche Uebersicht ueber den aktuellen Stand.

Typische Inhalte:

- aggregierte Kennzahlen
- sektor- oder tenantbezogene Sicht
- Portfolio-PDF

Fachlicher Nutzen:

- schneller Statusblick
- Kommunikation an Leitung, Programmsteuerung oder Kunden

Fuer Nicht-Sicherheitsleute:

Das Dashboard ist das Cockpit.

5.5 Catalog:

Zweck:

Normative und fachliche Struktur sichtbar machen.

Typische Inhalte:

- Domänen
- Struktur fuer Anforderungen
- fachliche Referenzbasis

Fachlicher Nutzen:

- gemeinsames Vokabular
- Vergleichbarkeit von Assessments

Fuer Nicht-Sicherheitsleute:

Der Catalog ist das Inhaltsverzeichnis der Bewertungslogik.

5.6 Requirements:

Zweck:

Anforderungen sichtbar und bearbeitbar machen.

Typische fachliche Fragen:

- Welche Pflicht existiert?
- Gilt sie fuer unseren Scope?
- Wie gut ist sie umgesetzt?
- Wo fehlt noch Nachweis?

Fachlicher Nutzen:

- Uebersicht ueber Soll-Anforderungen
- Bruecke zwischen Norm, Praxis und Nachweis

Fuer Nicht-Sicherheitsleute:

Hier steht, was man tun oder dokumentieren muss.

5.7 Processes:

Zweck:

Geschaeftsprozesse im Scope darstellen.

Typische Inhalte:

- Prozessname
- Scope
- Beschreibung
- Status
- Zuordnung zu Bereichen

Fachlicher Nutzen:

- Risiken und Anforderungen an echte Geschäftsabläufe anbinden
- Verantwortungen klarer machen

Für Nicht-Sicherheitsleute:

Ein Prozess ist ein geordneter Arbeitsablauf des Unternehmens.

5.8 Assets:

Zweck:

Informationswerte und wichtige Objekte dokumentieren.

Typische Asset-Beispiele:

- Anwendungen
- Datenbestände
- Infrastruktur
- Services
- Dokumentationen

Fachlicher Nutzen:

- Risiken an konkrete Werte koppeln
- Kritikalität nachvollziehbar machen

Für Nicht-Sicherheitsleute:

Assets sind die Dinge, die für das Unternehmen wichtig sind und geschützt werden müssen.

5.8.1 Zero Trust:

Zweck:

Endpoint- und Infrastruktur-Posture aus Agenten sichtbar machen.

Typische Inhalte:

- registrierte Agent-Devices
- letzter Heartbeat
- Zero-Trust-Score
- Policy-Profil mit Sollbestand nach Tenant, OS, Asset-Typ, Business Unit oder Deployment-Channel
- geführtes Agent-Onboarding für Windows, Linux, macOS und NixOS
- Enrollment-Token mit Ablauf, begrenzter Verwendung, Widerruf und Auditspur
- Soll-/Ist-Coverage, Heartbeat-Freshness und Finding-Grenzwerte je Policy
- nächster fachlicher Fokus aus Score, Severity und Agent-Freshness
- offene Findings nach Pillar und Severity
- Check-Katalog für Windows, macOS und Linux

Fachlicher Nutzen:

- technische Posture mit ISMS-Arbeit verbinden
- Findings in Risiken, Evidenzen und Roadmap-Arbeit überführen
- Zero-Trust-Optimierung nachvollziehbar und auditierbar machen
- Prioritäten schneller erkennen, ohne Rohdaten manuell vergleichen zu müssen
- Agent-Abdeckung, veraltete Heartbeats und kritische Findings in der Betriebszentrale überwachen
- Policy-Abweichungen über sichere Webhooks aktiv zustellen und in der Delivery-Historie auditieren

Für Nicht-Sicherheitsleute:

Der Bereich zeigt, welche Geräte welche Sicherheitslücken oder Nachweise melden.

Was die Agenten aktuell testen können:

- Inventar: Hostname, OS-Familie, OS-Version, CPU-Architektur, Agent-Version und Deployment-Channel
- Heartbeat: ob ein registriertes Gerät noch regelmäßig mit ISCY spricht
- OS-Baseline: Betriebssystem- und Patch-/Versionshinweise als Grundlage für MDM- oder Patch-Nachweise
- Datenträger-Verschlüsselung: BitLocker unter Windows, FileVault unter macOS, LUKS/root encryption unter Linux
- Plattformintegrität: Secure Boot unter Windows/Linux sowie SIP/authenticating root unter macOS

- Host-Firewall: Windows-Firewall-Profil, macOS Application Firewall, Linux firewalld/ufw/nftables/iptables-Signale
- MDM oder Endpoint Management: Windows Enrollment Registry, macOS profiles-Enrollment, Linux-Management-Agenten wie osquery, Puppet, Chef, Salt, SSM oder vergleichbare Agenten
- Endpoint Protection/EDR: Windows Defender Status, macOS EDR-/Security-Agent-Pfade, Linux-Dienste und Pfade fuer Wazuh, auditd, Microsoft Defender, CrowdStrike, SentinelOne, osquery und vergleichbare Agenten

Die Agenten arbeiten read-only. Wenn ein Signal nicht sicher bestaetigt werden kann, meldet ISCY eine offene Evidenzluecke statt einen erfundenen Nachweis.

Nach dem ersten tokenbasierten Enrollment speichert der Agent Device-ID und Agent-Secret lokal. Unter Unix sind State-Verzeichnis und State-Datei mit 0700 beziehungsweise 0600 geschuetzt; der Windows-Installer setzt restriktive ACLs. Temporaer nicht zustellbare Reports werden in einer standardmaessig auf 100 Eintraege begrenzten Offline-Queue gepuffert und beim naechsten Lauf zuerst uebertragen. Admins koennen das Secret ueber POST /api/v1/agents/devices/{deviceid}/rotate-secret rotieren; das neue Secret wird nur einmal ausgegeben und muss ueber den sicheren Deployment-Kanal zum Endpoint gelangen.

Administratoren koennen in /zero-trust/ ueber Agent hinzufuegen einen dreistufigen Assistenten starten. Zuerst werden Betriebssystem, Deployment-Kanal, optionale Rollout-Bezeichnung, Policy-Profil, Nutzungsgrenze, Ablaufzeit und optionale mTLS-Bindung ausgewaehlt. Danach zeigt ISCY eine Zusammenfassung. Erst nach der Bestaetigung wird das Token erzeugt und genau einmal zusammen mit einer Anweisung fuer die vorhandenen Windows-, systemd-, macOS- oder NixOS-Artefakte angezeigt.

Token-Klartexte werden nicht gespeichert. Die Metadatenansicht zeigt nur Hint, Status, Grenzen, Policy, Zaehler und Zeitpunkte. Die Zustaende sind pending, partiallyused, consumed, expired und revoked. Token-Verbrauch, Device-Aufnahme, Policy-Zuordnung, Secret-Hash und Auditereignis werden gemeinsam in einer Transaktion gespeichert. Read-only-Rollen duerfen sichere Metadaten sehen; Erstellen, Widerrufen und die einmalige Installationsansicht bleiben Administratoren vorbehalten.

Policy-Profil legen den erwarteten Device-Bestand, das maximale Heartbeat-Alter, den Mindestscore und tolerierte High-/Critical-Findings fest. Administratoren koennen Webhook-Kanaele mit Warnstufe und Cooldown konfigurieren. Bearer- und HMAC-Secrets werden dabei nur ueber Environment-Variablenamen referenziert und nicht in der Datenbank gespeichert. Im Production-Modus sind ausschliesslich explizit erlaubte Zielhosts zulaessig; Redirects werden nicht verfolgt. Jeder Versuch bleibt mit Ergebnis, HTTP-Status und Payload nachvollziehbar.

Die Weboberflaeche stellt Zero Trust bewusst als Arbeitsansicht dar:

- Score-Karte fuer die aktuelle Zero-Trust-Reife
- Fokuskarte fuer den naechsten sinnvollen Schritt
- Severity-Badges fuer kritische, hohe, mittlere und niedrige Findings
- mobile Navigation und horizontale scrollbare Tabellen fuer kleine Displays
- konservative Darstellung ohne automatische Remediation

5.9 Risks:

Zweck:

Risiken erfassen, bewerten und behandeln.

Kernlogik:

- Beschreibung des Risikos
- Bedrohung
- Schwachstelle
- Impact
- Likelihood
- Risikostufe
- Behandlungsstrategie
- Fristen und Reviews
- Review-Workflow fuer Behandlung, Akzeptanz, Mitigation und Abschluss
- automatische CVE-Risiken aus akzeptierten Product-Security-Korrelationen

Fachlicher Nutzen:

- zentrales Risikoregister
- transparente Priorisierung
- Nachvollziehbarkeit von Entscheidungen
- fachlicher Review von automatisch erzeugten Schwachstellenrisiken

Fuer Nicht-Sicherheitsleute:

Ein Risiko ist in ISCY kein Technikfehler, sondern eine moegliche negative Geschaeftsauswirkung.

5.10 Assessments:

Zweck:

Umsetzungs- und Nachweisstand strukturiert dokumentieren.

Teilfunktionen:

- Applicability

fachliche Frage: Gilt eine Anforderung fuer uns?

- Measures

fachliche Frage: Welche Massnahme setzen wir um?

- Statement of Applicability (SoA)

fachliche Frage: Welche ISO-27001 Controls sind relevant, umgesetzt oder ausgeschlossen?

- Audits

fachliche Frage: Was wurde geprueft und was wurde gefunden?

- Findings

fachliche Frage: Welche Abweichungen oder Schwachstellen wurden festgestellt?

- Management Reviews

fachliche Frage: Wie bewertet die Leitung den Gesamtstand?

- Review Actions

fachliche Frage: Welche Folgeaktionen beschliesst die Organisation?

Fachlicher Nutzen:

- Kernbereich fuer ISMS-Nachweisfuehrung

- interne und externe Auditvorbereitung

- Management-Einbindung

Fuer Nicht-Sicherheitsleute:

Hier wird aus "wir glauben, dass wir gut sind" ein belastbarer und pruefbarer Nachweis.

5.11 Evidence:

Zweck:

Nachweise sammeln, pflegen und mit Bedarfen verknuepfen.

Typische Funktionen:

- Evidence hochladen

- Evidence aktualisieren

- Evidence Needs synchronisieren

- Evidence direkt aus Risks, Roadmap-Tasks, Incidents und Product-Security-Kontexten vorbefuellen

- nach dem Speichern automatisch zur Ausgangsseite zurueckkehren

- Evidence-Qualitaet unter /evidence/quality/ auswerten

- Score, Reifegrad und Issues fuer Nachweise und Evidence Needs anzeigen

- Datei-Uploads automatisch mit SHA-256 kennzeichnen

- Nachweise ueber Vorgaenger-ID und serverseitige Versionsnummer versionieren

- Gueltigkeit, Aufbewahrungsfrist, Retention-Begrueundung und Schutzklasse pflegen

- abgelaufene und innerhalb von 30 Tagen ablaufende Nachweise in Quality-Queue und Betriebszentrale erkennen

- Version, Schutzklasse, Gueltigkeit und SHA-256 in Incident-/Regulatory-Exporten ausweisen

Fachlicher Nutzen:

- Nachweisfuehrung an einem Ort

- bessere Auditfaehigkeit

- weniger Suche nach Dokumenten

- klarere Rueckverfolgbarkeit durch stabile Linked-Requirement- und Evidence-Key-Bezuege

- belastbarere Aussage, ob Nachweise nur vorhanden oder wirklich reviewt und verwertbar sind

- nachvollziehbare Integritaet und Lifecycle-Steuerung ohne pauschal fest codierte gesetzliche Aufbewahrungsfrist

Fuer Nicht-Sicherheitsleute:
Evidence ist der Ordner mit den Belegen, aber strukturiert und auswertbar.

5.12 Reports:

Zweck:
Ergebnisse in lesbare und versendbare Form bringen.

Ausgaben:

- Report-Detailseite
- einfaches PDF
- audit-faehiges PDF
- Management-Review-Pakete unter /management-reviews/
- Management-Review-Exporte als Markdown, HTML, PDF und JSON

Management-Review-Pakete:

- werden aus aktuellen ISCY-Daten fuer einen Zeitraum erzeugt
- koennen als generisches Security-Governance-Paket oder ueber Templates fuer ISO 27001, NIS2, DORA und KRITIS vorbereitet werden
- speichern Top-Risiken, ISCY-27-Control-Gaps, Evidence-Luecken, Incident-Entscheidungen, Roadmap-Fokus, Product-Security-Lage, Supplier-Review-Summary, Agent-Posture, AI-Governance, Quellenzaehlung, Gap-Summary, Management-Hinweise und regulatorischen Kontext als Snapshot
- verlinken Snapshot-Zeilen zurueck zu Risiko, Control, Evidence, Incident und Roadmap
- koennen von Draft ueber In Review bis Approved oder Archived gefuehrt werden
- dokumentieren Entscheidung, naechste Massnahmen, freigebenden User und Freigabezeitpunkt
- erlauben eine Template-Vorschau, ohne bereits ein Review-Paket einzufrieren

API- und Web-Pfade:

- GET /api/v1/management/templates
- GET /api/v1/management/templates/{templatetype}
- POST /api/v1/regulatory/templates/{templatetype}/preview
- GET und POST /api/v1/management/reviews
- Weboberflaeche unter /management-reviews/ mit Template-Auswahl und Preview

Fachlicher Nutzen:

- Management-Kommunikation
- Dokumentationsstand
- Vorlagen fuer Kunden, Auditoren oder interne Gremien
- belastbare Vorbereitung von Management Review, Audit und Steering Committee
- wiederholbare Steuerungspakete, ohne neue Risiko-, Evidence- oder Control-Silos anzulegen

Fuer Nicht-Sicherheitsleute:
Reports sind die offizielle Zusammenfassung des Stands.

5.13 Roadmap:

Zweck:
Aus Ergebnissen konkrete Arbeit machen.

Typische Funktionen:

- Planliste
- Plandetail
- Kanban-Ansicht
- Task-Bearbeitung
- PDF- und PNG-Export
- direkte Evidence-Verknuepfung je Roadmap-Task

Fachlicher Nutzen:

- Transformation von Analyse in Umsetzungsprogramm
- Priorisierung nach Wirkung und Aufwand
- Nachweisfuehrung dort starten, wo die Umsetzungsarbeit entsteht

Fuer Nicht-Sicherheitsleute:
Die Roadmap ist der Umsetzungsfahrplan.

5.14 Import Center:

Zweck:

Bestehende Daten strukturiert nach ISCY uebernehmen.

Typische Funktionen:

- Import Guide
- Mapping Assistant
- Vorschau
- Template-Download

Importierbare Inhalte:

- Business Units
- Prozesse
- Lieferanten
- Assets

Fachlicher Nutzen:

- schneller Projektstart
- weniger manuelle Datenerfassung
- bessere Datenqualitaet durch Mapping

Fuer Nicht-Sicherheitsleute:

Das Import Center ist die Uebersetzungsstelle fuer vorhandene Tabellen in das ISCY-Datenmodell.

5.15 Product Security:

Zweck:

Sicherheitsaspekte digitaler Produkte verwalten.

Typische Objekte:

- Product Family
- Product
- Product Release
- Component
- AI System
- Threat Model
- Threat Scenario
- TARA
- Vulnerability
- VEX-Entscheidung
- PSIRT Case
- CSAF-/SBOM-Importhistorie
- SBOM-Diff
- CVE-Asset-Korrelation
- CVE-Risiko-Review-Queue
- CRA-Readiness
- versioniertes Release-/PSIRT-Evidence-Paket

Fachlicher Nutzen:

- Anbindung von Produktentwicklung und Sicherheitsgovernance
- Vorbereitung fuer CRA, IEC 62443, ISO/SAE 21434 oder AI-bezogene Governance
- Sicht auf Releases, Komponenten und Verwundbarkeit
- strukturierte Verarbeitung von CSAF-Advisories, CycloneDX/SPDX-SBOMs und CVE-Korrelationen
- auditierbare VEX-Entscheidung je Schwachstelle mit Status, Begrueendung, Fix-Version und Zeitpunkt
- SBOM-Vergleich zwischen Importstaenden, damit neue, entfernte und geaenderte Komponenten sichtbar werden
- CRA-Readiness je Produkt aus SBOM, VEX/CVE-Triage, PSIRT/Advisories, Threat/TARA und Lifecycle
- automatische Ableitung von Risiko- und Roadmap-Arbeit aus akzeptierten CVE-Korrelationen
- Nachweissteuerung ueber Evidence-Keys fuer CVE, Import, Risiko und Roadmap
- dokumentierte Release-/PSIRT-Entscheidungen mit eingefrorenem Nachweisstand und Blocker-Gates

Fuer Nicht-Sicherheitsleute:

Dieser Bereich ist fuer Unternehmen wichtig, die Software, digitale Produkte oder vernetzte Systeme bereitstellen.

Aktueller Rust-Funktionsumfang:

- Import-Historie fuer CSAF, CycloneDX und SPDX mit CSV-/JSON-Export
- Import-Detailseite mit Validierungsfehlern und Komponenten-Matches
- SBOM-Diff als Webansicht und API fuer zwei SBOM-Importartefakte
- VEX-Status fuer Schwachstellen: betroffen, nicht betroffen, behoben oder in Untersuchung
- CRA-Readiness-Dashboard je Produkt mit transparenten Dimensionen und Gap-Hinweisen
- CVE-Asset-Korrelation ueber CPE oder PURL mit Akzeptieren/Ablehnen-Workflow
- automatische Erzeugung von CVE-Risiken und Product-Security-Roadmap-Tasks aus akzeptierten Korrelationen
- Dashboard-Kennzahlen fuer offene CVE-Reviews und fehlende Evidence
- gebuendelte CVE-Risiko-Review-Queue mit Filtern fuer offene Reviews, fehlende Evidence und fehlende Risiken
- Bulk-Aktionen fuer ausgewaehlte CVE-Reviews: Risiko/Roadmap erzeugen, Behandlung freigeben, Restrisiko akzeptieren oder als mitigiert markieren
- Einzelaktionen fuer Behandeln, Akzeptieren und Mitigiert markieren
- Evidence-Vorbefuellung und Ruecksprung zur Ausgangsseite nach Upload
- Paketregister unter /product-security/evidence-packages/ fuer Release- und PSIRT-Scope
- versionierte Snapshots aus Lifecycle, SBOM, VEX, Advisories, Risiko-/Roadmap-Stand und Evidence
- Review-Workflow mit Entwurf, Review, Aenderungsanforderung, Freigabe und Archivierung
- vorbehaltlose Freigabe nur ohne Blocker; bedingte Freigabe nur mit dokumentierter Review-Notiz
- Markdown-, HTML-, PDF- und JSON-Export je Paketversion
- Betriebsstatus fuer Paket-Backlog und offene Blocker

5.16 AI Governance:

Zweck:

KI-Systeme als eigene Governance-Objekte steuern.

AI Governance umfasst AI-Systeme, die in Produkten, internen Prozessen oder Support-/Triage-Flows genutzt werden. ISCY trennt dabei nicht nur nach Regulierung, sondern fragt funktional: Welchen Zweck hat das System, welche Daten nutzt es, welche Wirkung haben seine Empfehlungen oder Entscheidungen, wer prueft die Ergebnisse und welche Evidence belegt Betrieb, Review und Kontrolle?

Typische Objekte:

- AI System
- Produktbezug
- Modellquelle und Provider
- Datenkategorien
- Entscheidungswirkung
- Human Oversight
- AI-Act-Klassifizierung
- Monitoringplan
- Risikosummary
- Evidence-Key

Aktueller Rust-Funktionsumfang:

- Webansicht /ai-governance/ mit AI-Systemregister, Kennzahlen, Review-Faelligkeit, Evidence-Stand und Governance-Gaps
- API GET und POST /api/v1/ai-governance/systems
- API GET und PATCH /api/v1/ai-governance/systems/{id}
- API GET /api/v1/ai-governance/systems/{id}/link-candidates
- API POST und DELETE /api/v1/ai-governance/systems/{id}/links/{typ}/{objekt-id} fuer Risiken, Roadmap-Tasks, Incidents und Changes
- API POST /api/v1/ai-governance/systems/{id}/gap-tasks fuer die ausdruecklich ausgeloeeste Task-Erzeugung
- AI-Act-Klassen: nicht bewertet, High Risk, Limited Risk, Minimal Risk, nicht im Scope und verboten/nicht freigegeben
- Anforderungen fuer Klassifizierung, Risikomanagement, Human Oversight, Logging, Transparenz, Cybersecurity/Robustheit sowie Monitoring/Evidence
- Evidence-Vorbefuellung ueber stabile AI-Governance-Evidence-Keys
- direkte, im SQL tenantgebundene Verknuepfungen mit bestehenden Risiken, Roadmap-Tasks und Incidents
- kleines allgemeines Change-Register als kanonischer Plattformkern; es ist kein

AI-spezifisches Ersatzmodell und noch kein vollstaendiger Change-Management-Workflow

- Link-Audit fuer Anlegen und Entfernen mit Actor, Objekttyp, Objekt-ID und Zeitpunkt
- Roadmap-Tasks aus offenen Governance-Gaps nur nach Nutzeraktion; originkey und Unique-Index verhindern Duplikate auch bei Wiederholung
- Management-Review-Snapshots und Exporte frieren AI-Systeme sowie Linkzaehler fuer Risiko, Roadmap, Incident und Change ein; Management-/Regulatory-Templates nehmen diese Daten in den passenden Review-Kontext auf
- Rust-only-Betriebssignale fuer nicht bewertete AI-Systeme, faellige Reviews, fehlende Evidence und offene Governance-Gaps

Tenant- und Berechtigungsgrenzen:

- Leser und Auditoren koennen die Verknuepfungen sehen, aber nicht aendern.
- Schreibende Rollen duerfen Links und Gap-Tasks verwalten.
- AI-System und Zielobjekt werden bereits in der Datenbankabfrage auf denselben Tenant eingeschränkt. Manipulierte oder fremde IDs werden nicht verknuepft und nicht offengelegt.
- Management-Review-Pakete enthalten einen unveraenderlichen Snapshot. Spaetere Linkaenderungen schreiben alte Pakete nicht um.

Fachlicher Nutzen:

- AI-Systeme werden nicht nur als Produktmerkmal, sondern als steuerbares Risiko- und Governance-Objekt sichtbar.
- AI-Act-, ISMS-, Product-Security- und Evidence-Arbeit laufen ueber dasselbe Nachweis- und Review-Modell.
- Fachliche Reviews koennen frueh erkennen, ob Einstufung, Oversight, Monitoring oder Evidence fehlen.

Die technischen API-, Tenant- und Snapshot-Regeln sind in docs/AIGOVERNANCE.md gebuendelt.

Fuer Nicht-Sicherheitsleute:

Dieser Bereich beantwortet: Welche KI wird genutzt, wofuer, mit welchen Risiken, wer kontrolliert sie und wo ist der Nachweis?

5.17 Supplier Risk:

Zweck:

Externe Abhaengigkeiten als eigenen Risikobereich steuern.

Supplier Risk umfasst Lieferanten, Cloud-Provider, SaaS-Dienste, IKT-Drittdienstleister, Produktzulieferer, Komponentenhersteller und Audit-/Nachweisportale. ISCY fuehrt diese Objekte nicht nur als Adressliste, sondern als Third-Party-Risk-Register.

Aktueller Rust-Funktionsumfang:

- Webansicht /suppliers/ mit Supplier-Risk Register, Score, Kritikalitaet, Review-Status, Evidence-Stand und Exposure
- Web-Detailansicht /suppliers/{id}/ mit Reviewhistorie, Unterauftragnehmern, Vertrags-/Exit-Daten, Evidence-/Control-/Risk-Links und Auditspur
- API GET und POST /api/v1/suppliers fuer Uebersicht und Anlage sowie GET und PATCH /api/v1/suppliers/{id} fuer Detaildaten und Aktualisierung
- API GET und POST /api/v1/suppliers/{id}/reviews fuer Review-/Approval-Ereignisse
- API GET und POST /api/v1/suppliers/{id}/subprocessors sowie PATCH /api/v1/suppliers/{id}/subprocessors/{subprocessorid} fuer Unterauftragnehmer im Supplier-Kontext
- API GET /api/v1/suppliers/{id}/evidence, POST /api/v1/suppliers/{id}/evidence-links, POST /api/v1/suppliers/{id}/control-links und POST /api/v1/suppliers/{id}/risk-links fuer explizite Nachweis-, Control- und Risiko-Bezeuge
- Datenfelder fuer Vertrags-/Security-Annex-Bezug, Security-Kontakt, Datenarten, Regionen, Exit-Abhaengigkeit, regulatorischen Scope, Review-Status, Review-Faelligkeit und Notes
- additive Migration 0031rustsupplierreviewworkflow fuer Review-Freigaben, Subprocessors, Vertragslaufzeiten, Exit-Test-Nachweise und Link-/Audit-Tabellen
- automatische Signale aus Produktkomponenten, offenen Product-Security-Schwachstellen, Supplier-bezogenen Risiken und Supplier-Evidence
- direkte Evidence-Vorbefuellung je Supplier mit stabilem Linked Requirement SUPPLIER:{id}
- Score- und Issue-Logik fuer kritische CVEs, ueberfaellige Reviews, fehlende Evidence, fehlende Exit-Strategie, fehlenden Security-Kontakt und fehlende Risikodokumentation
- Review-Statusmodell: draft, inreview, approved, approvedwithconditions, rejected, expired und archived
- Exit-Test-Statusmodell: notrequired, required, planned, passed, failed und overdue
- Begruebungspflicht fuer approvedwithconditions und rejected
- tenantgebundene Validierung fuer Supplier, Subprocessors, Owner, Evidence, Controls und

Risiken

- auditierbare Erstellung, Aenderung, Statusentscheidung, Subprocessor-Aenderung und Link-Verwaltung ohne Secrets, SQL-Details oder vertrauliche Payloads

Fachlicher Nutzen:

- DORA-IKT-Drittparteienrisiko, NIS2-Supply-Chain-Anforderungen, CRA-Komponenten-/Herstellerbezug, DSGVO-Datenverarbeitung und TISAX-Lieferkettennachweise koennen gemeinsam betrachtet werden.
- Kritische externe Abhaengigkeiten werden sichtbar, bevor sie erst in einem Incident auffallen.
- Evidence, Risiken, Product Security und Roadmap-Arbeit bekommen einen gemeinsamen Lieferantenbezug.
- Review-Entscheidungen werden nicht nur als aktueller Status gespeichert, sondern als nachvollziehbare Freigabehistorie.
- Vertragsende, automatischer Renew, Kuendigungsfrist und Exit-Test-Status helfen dabei, Abhaengigkeiten vor Ablauf, Eskalation oder Lieferantenwechsel zu steuern.

Rollen- und Sicherheitsmodell:

- Admin- und Editor-Rollen duerfen Supplier, Reviews, Subprocessors und Links schreiben.
- Read-only-Rollen sehen sichere tenantgebundene Metadaten.
- Fremde Tenant-Objekte, manipulierte Supplier-IDs sowie fremde Evidence-, Risk- und Owner-IDs werden nicht aufgeloeset.
- Interne Store- oder SQL-Fehler werden in API und Web UI nicht als technische Details ausgegeben.

Bewusst nicht Teil dieses Moduls:

- keine neue Evidence-Engine
- keine neue Risiko-Engine
- keine neue Control-Bibliothek
- kein Legal-Hold-, Disposition-, Loesch-, Re-Hash- oder Objektspeichersystem

Fuer Nicht-Sicherheitsleute:

Dieser Bereich beantwortet: Von welchen externen Parteien haengt unser Betrieb ab, wie kritisch sind sie, welche Nachweise fehlen und wo entsteht daraus Risiko?

5.18 Vulnerability Intelligence:

Zweck:

Bekannte Schwachstellen fachlich und technisch bewerten.

Was der Bereich jetzt leisten soll:

- CVE aus NVD laden
- lokale Risikoanalyse durchfuehren
- optionales lokales LLM-Enrichment
- EPSS- und KEV-Kontext beruecksichtigen
- NIS2-Relevanz und kritische Services einbeziehen
- Git-/Repository- und Paketkontext speichern
- Risiko- und Vulnerability-Objekte automatisch verknuepfen

Fuer lokale Tests und air-gapped Prueflaeufe kann der NVD-Import statt eines HTTP-Endpunkts auch eine lokale NVD-JSON-Datei lesen, wenn NVDAPIBASEURL als `file:///pfad/zur/nvd-response.json` gesetzt wird.

Fachlicher Nutzen:

- bessere Priorisierung als nur CVSS
- Verbindung zwischen Technik, Betrieb und Regulierung
- Grundlage fuer PSIRT, Patch-Steuerung und Management-Kommunikation

Fuer Nicht-Sicherheitsleute:

Hier wird aus einer technischen Schwachstellenmeldung eine geschaeftlich nutzbare Bewertung.

6. Typische Arbeitsablaeufe:

6.1 Erstaufbau eines ISMS:

1. Tenant anlegen
2. Wizard durchlaufen

3. Prozesse, Assets und Lieferanten importieren
4. Requirements und Applicability sichten
5. erste Risiken erfassen
6. Evidence aufbauen
7. SoA generieren
8. Report und Roadmap erzeugen

6.2 Auditvorbereitung:

1. offene Findings und Reviews sichten
2. Evidence Needs synchronisieren
3. Nachweise aktualisieren
4. SoA prüfen
5. Audit-Report erzeugen

6.3 NIS2-orientierte Arbeitsweise:

1. Tenant als NIS2-relevant markieren
2. kritische Services klar beschreiben
3. Prozesse, Assets und Risiken auf wesentliche Dienste beziehen
4. Schwachstellen mit NIS2-Kontext bewerten
5. Reports fuer Leitung und Nachweiszwecke verwenden

6.4 Produkt- und Schwachstellensteuerung:

1. Produkte, Releases und Komponenten pflegen
2. CSAF-Advisories oder SBOMs importieren und Validierungsfehler prüfen
3. SBOM-Importstaende vergleichen und neue, entfernte oder geänderte Komponenten bewerten
4. VEX-Status fuer Schwachstellen dokumentieren: betroffen, nicht betroffen, behoben oder in Untersuchung
5. Komponenten-Matches ueber CPE oder PURL kontrollieren
6. CVE-Asset-Korrelationen vorschlagen lassen
7. Korrelationen fachlich akzeptieren oder ablehnen
8. Aus akzeptierten Korrelationen Risiko- und Roadmap-Arbeit erzeugen
9. CVE-Risiko-Review-Queue abarbeiten
10. Evidence direkt aus Queue, Risiko oder Roadmap-Task hochladen
11. CRA-Readiness je Produkt prüfen und Massnahmen ueber Roadmap oder Risiko-Behandlung steuern

6.5 Incident- und NIS2-Meldeworkflow:

Die Rust-Webroute /incidents/ fuehrt operative Sicherheitsvorfaelle als mandantenfaehige Fallakten. Ein Incident kann Reporter, Owner, Risiko, Asset und Prozess referenzieren und enthaelt Typ, Runbook, Status, Severity, Stakeholder-Zusammenfassung sowie Behoerden- oder Case-Referenz. Tenantbezogene Runbook-Vorlagen werden in incidentsrunbooktemplate gepflegt, per /api/v1/incidents/runbook-templates ausgeliefert und koennen beim Anlegen eines Incidents direkt als bearbeitbare Startvorlage uebernommen werden.

ISCY trennt bewusst zwischen einem Security Incident und einem erheblichen Sicherheitsvorfall. Nicht jeder operative Sicherheitsvorfall ist automatisch NIS2-meldepflichtig. Die Fallakte kann deshalb zuerst als normaler Incident entstehen und danach fachlich bewertet werden.

Die NIS2-Erheblichkeitsentscheidung wird in ISCY mit vier Status gefuehrt:

1. Nicht bewertet
2. Nicht erheblich
3. Wahrscheinlich erheblich
4. Erheblich / NIS2 meldepflichtig

Zur Begrueundung koennen Kriterien, Entscheidungstext, Referenz und Bewertungszeitpunkt gepflegt werden. Fachlich orientiert sich die Bewertung an NIS2 Art. 23. Die Durchfuehrungsverordnung (EU) 2024/2690, insbesondere Art. 3, wird in ISCY als Best-Practice-Referenz genutzt, auch wenn ihr unmittelbarer Pflichtbereich nur bestimmte Entitaeten betrifft. Dadurch wird sichtbar, warum ein Fall meldepflichtig ist oder warum er bewusst nicht als erheblicher Sicherheitsvorfall behandelt wird.

Erst wenn ein Incident auf Erheblich / NIS2 meldepflichtig gesetzt wird, berechnet ISCY die relevanten Fristen aus dem Erkennungszeitpunkt:

1. 24h-Fruehwarnung
2. 72h-Meldung
3. Abschlussbericht nach 30 Tagen

Die Uebersicht zeigt offene Faelle, Erheblichkeitsstatus, NIS2-relevante Faelle und ueberfaellige Meldeschritte. Gesendete Meldungen koennen ueber die API als Zeitstempel gepflegt werden. Damit vermeidet ISCY eine Angstlogik nach dem Motto "24 Stunden fuer alles" und erzwingt stattdessen eine nachvollziehbare fachliche Entscheidung.

Die Detailseite `/incidents/{id}` dient als operative Fallakte. Dort koennen berechnigte Rollen Typ, Runbook, Status, Severity, Erheblichkeitsentscheidung, Behoerdenreferenz, Zeitlinie und Meldezeitpunkte pflegen; die Runbook-Bibliothek wird als Referenz direkt neben der Fallakte angezeigt. Eine Entscheidungsleiste fuehrt von Vorfall ueber Erheblichkeit und Bearbeitung bis zum Meldepaket und springt direkt in die passenden Abschnitte. ISCY dokumentiert die Anlage der Fallakte, Statuswechsel, NIS2-Erheblichkeitsaenderungen, automatisch angeforderte Reviews, manuelle Timeline-Notizen und incidentbezogene Evidence-Uploads als Timeline-/Audit-Events mit Actor, Zeitpunkt, Ereignisart und Detailtext. Ein Incident wird dabei nicht automatisch als erheblicher Sicherheitsvorfall behandelt: Wird eine Fallakte als Nicht erheblich bewertet, fordert ISCY automatisch Review/Freigabe an und laesst die NIS2-Meldefristen inaktiv, bis die Einstufung ggf. auf Erheblich / NIS2 meldepflichtig geaendert wird. Manuelle Notizen koennen auch ueber `POST /api/v1/incidents/{id}/timeline-notes` automatisiert erfasst werden. Evidence-Uploads koennen ueber incidentid direkt an einen Incident gekoppelt werden und erscheinen in der Fallakte; fuer berechnigte Rollen steht der Upload direkt auf der Incident-Detailseite bereit. Alertmanager-Fallakten werden ueber Fingerprint oder Alertname dedupliziert; resolved Alerts schliessen passende offene Fallakten automatisch und sind in `/operations/incidents/` als Betriebsuebersicht mit Filtern fuer open, critical und resolved sichtbar. Optional kann `ISCYALERTMANAGERREQUIRERESOLUTIONREVIEW=1` gesetzt werden, damit automatisch geschlossene Alert-Fallakten ohne Lessons Learned als Review-Pflicht fuer Root Cause und Lessons Learned markiert werden. Das Meldepaket unter `/incidents/{id}/nis2-export` buendelt Fallakte, NIS2-Erheblichkeitsentscheidung, regulatorische NIS2/DORA/DSGVO-Entscheidungsmatrix, Runbook, verknuepfte Evidence, Audit-Timeline, betroffene Bezuege, 24h-/72h-/30-Tage-Fristen, Stakeholder-Zusammenfassung und Lessons Learned; zusaetzlich stehen HTML und PDF ueber `/incidents/{id}/nis2-export.html` und `/incidents/{id}/nis2-export.pdf` bereit. DORA-Pruefpakete koennen ueber `/incidents/{id}/dora-export`, `/incidents/{id}/dora-export.html` und `/incidents/{id}/dora-export.pdf` erzeugt werden; DSGVO-Pruefpakete entsprechend ueber `/incidents/{id}/dsgvo-export`, `/incidents/{id}/dsgvo-export.html` und `/incidents/{id}/dsgvo-export.pdf`. Das Dashboard zeigt zudem Incidents ohne abgeschlossene Erheblichkeitsbewertung als klickbare Kennzahl und fuehrt direkt zur gefilterten Incident-Liste.

6.6 SOC-Playbook fuer Phishing- und aehnliche Incident-Faelle:

Empfohlene Kette fuer die operative Bearbeitung:

1. Scope bestimmen

Klaeren, wer und was betroffen ist, seit wann der Vorfall laeuft und welche Systeme, Konten, Daten oder Geschaefsbereiche im Risiko stehen.

2. Informationen korrelieren

Mail-Logs, SEG, SIEM, EDR, Auth-, Proxy-, DNS- und Firewall-Daten zusammenfuehren.

3. Nach Gemeinsamkeiten suchen

IOCs und TTPs vergleichen (Domain, URL, Hash, Prozesse, Zeitfenster, Zielgruppe).

4. Vorfall bewerten

Einordnen, ob Spam, Phishing, BEC, Malware Delivery oder bereits Account Compromise vorliegt.

5. Verdacht bestaetigen

Von der Hypothese in die Incident-Response wechseln, sobald belastbare Evidenz vorliegt.

6. Priorisieren

Kritikalitaet und Dringlichkeit anhand Impact, Privilege-Level, Ausbreitungs- und Datenabflussrisiko einstufen.

7. Dokumentieren

Nachvollziehbar festhalten, was bekannt ist, was vermutet wird, was getan wurde und warum.

8. Containment einleiten

Sofortmassnahmen risikobasiert umsetzen (z. B. Mail entfernen, URL blockieren, Session widerrufen, Konto sichern, Host isolieren).

9. Gegebenenfalls eskalieren

An L2/L3, IR, IAM, Management, Datenschutz oder Legal uebergeben, wenn Risiko, Scope oder Komplexitaet es erfordern.

Merksatz: Erst verstehen, dann bewerten, dann eindaemmen, dann eskalieren - wenn Risiko oder Komplexitaet es verlangen.

6.7 ISCY lokal auf NixOS starten:

Einfachster lokaler Start:

```
cd /home/enricow79/Projekte/ISCY
./start.sh
```

Danach ist ISCY unter <http://127.0.0.1:9000/login/> erreichbar.

Demo-Login:

admin / Admin123!

Ohne Wrapper kann der Rust-Service so initialisiert und gestartet werden:

```
nix run .#iscy-backend -- init-demo
DATABASE_URL=sqlite:///db.sqlite3 RUST_BACKEND_BIND=127.0.0.1:9000 nix run .#iscy-backend
```

Produktive Erstinitialisierung erfolgt ohne Demo-Seed. Dafuer wird ein eigenes Passwort aus einer Secret-Datei gelesen und ein initialer Admin angelegt:

```
ISCY_INITIAL_ADMIN_PASSWORD_FILE=/run/secrets/iscy-initial-admin-password \
nix run .#iscy-backend -- init-admin
```

Maschinenlesbarer Betriebsstatus fuer lokale Pruefung, Monitoring und Agenten:

```
curl -fsS http://127.0.0.1:9000/health/live
curl -fsS http://127.0.0.1:9000/status/operations.json
curl -fsS http://127.0.0.1:9000/metrics
```

Alertmanager kann Betriebsalarme an ISCY melden:

```
curl -fsS -X POST http://127.0.0.1:9000/api/v1/operations/alertmanager \
-H 'content-type: application/json' \
-d '{"receiver":"iscy-operations","status":"firing","alerts":[]}'
```

Ohne Tenant-/User-Kontext wird der Alert nur normalisiert. Mit schreibendem Tenant-Kontext erzeugt ISCY fuer firing Alerts automatisch eine Incident-Fallakte, verknuepfte Evidence und einen Timeline-Eintrag. Wiederholte firing Alerts werden dedupliziert, resolved Alerts schliessen die passende offene Alert-Fallakte automatisch. Die Alert-Operations-Seite </operations/incidents/> bietet direkte Filter fuer open, critical und resolved. Wird `ISCYALERTMANAGERREQUIRERESOLUTIONREVIEW=1` gesetzt, markiert ISCY automatisch geschlossene Alert-Fallakten ohne Lessons Learned als Review-Pflicht. Das Monitoring-Beispiel nutzt fuer lokale Demo-Stacks Tenant 1, User 2 und Rolle CONTRIBUTOR; User 2 ist der per Demo-Seed angelegte technische Operations-User ops-alertmanager.

Mit Tenant-Kontext enthaelt der Betriebsstatus zusaetzlich fachliche Signale zu ISCY-27, Supplier-Risk, Product Security, AI Governance, offenen CVE-Reviews, fehlender Evidence, Migrationen, Runtime-Flags und verbundenen Rust-Modulen:

```
curl -fsS -H 'x-iscy-tenant-id: 1' -H 'x-iscy-user-id: 1' \
'http://127.0.0.1:9000/api/v1/status/operations?tenant_id=1&user_id=1'
curl -fsS -H 'x-iscy-tenant-id: 1' -H 'x-iscy-user-id: 1' \
'http://127.0.0.1:9000/api/v1/status/metrics?tenant_id=1&user_id=1'
```

Die Prometheus-/Grafana-Betriebsdoku liegt in [docs/OPERATIONSMONITORING.md](#).

Fuer Community-Readiness und Production-Hardening sind zusaetzlich diese Dokumente verbindlich:

- [docs/COMMUNITYREADINESSPHASE0PHASE1.md](#) beschreibt die aktuelle Gap-Liste und den Status READY WITH DOCUMENTED LIMITATIONS.
- [docs/CONFIGURATION.md](#) dokumentiert Betriebsmodi, Secrets, Proxy-Grenzen und sichere Defaults.
- [docs/TLSANDREVERSEPROXY.md](#) beschreibt HTTPS-Terminierung, HSTS und die Behandlung von x-iscy- Identity-Headern.
- [docs/AUTHORIZATIONMODEL.md](#) beschreibt Session-, Header- und Rollenmodell inklusive Negativtests.
- [docs/PRODUCTIONHARDENING.md](#) beschreibt den Production-Preflight, Security-Header und offene Phase-1-Risiken.

Im Production-Modus (`ISCYAPPMODE=production`) bricht ISCY den Start ab, wenn kritische Annahmen fehlen: keine Datenbank, Beispiel-Secrets, aktive Demo-Zugangsdaten, Demo-Seeding, unsichere Cookies, oeffentliche Bind-Adresse ohne bestaetigten Reverse Proxy, HSTS ohne bestaetigtes HTTPS oder fehlendes Alertmanager-Secret. Normale Clients duerfen x-iscy-tenant-id, x-iscy-user-id oder x-iscy-roles produktiv nicht zur Identitaetssteuerung verwenden; diese

Header werden nur akzeptiert, wenn ein vertrauenswürdiger Proxy das explizit absichert.

Lokale Logins sind gegen einfache Brute-Force-Schleifen begrenzt: Nach fuenf fehlgeschlagenen Versuchen pro Tenant/Username blockiert ISCY weitere Versuche fuer 15 Minuten. Mit angewendeter Migration 0023rustsecurityruntimestate wird dieser Zustand im Security-Store persistiert und kann von mehreren Backend-Instanzen gemeinsam genutzt werden. Der Alertmanager-Webhook kann zusaetzlich zum Bearer-Token mit ISCYALERTMANAGERHMACSECRETFILE signierte timestamp.body-Requests verlangen; das Replay-Fenster wird ueber ISCYALERTMANAGERHMACMAXAGESECONDS gesteuert. Optional kann x-iscy-alert-nonce gesendet werden; bei aktivem Security-Store speichert ISCY verwendete Nonces im Replay-Fenster und lehnt Wiederholungen ab.

Die Tenant-Isolation wird nicht nur auf Listen, sondern auch auf sensible Objektoperationen angewendet. Negativtests decken fremde Detail-, Write- und Exportzugriffe fuer Kernobjekte ab, darunter Incidents mit NIS2-/DORA-/DSGVO- und Timeline-Exporten sowie Management-Review-Pakete. Evidence-Uploads duerfen keine Session und keinen Incident eines fremden Tenants referenzieren. ISCY antwortet in diesem Fall ohne Fremdmandantendaten mit 400 invalidevidenceupload und entfernt die bereits temporaer gespeicherte Datei.

Fuer den direkten Monitoring-Betrieb liegen diese Artefakte im Repository:

- deploy/monitoring/prometheus/iscy-scrape.yml
- deploy/monitoring/prometheus/iscy-operations-alerts.yml
- deploy/monitoring/alertmanager/iscy-alertmanager.yml
- deploy/monitoring/grafana/iscy-operations-dashboard.json
- deploy/monitoring/docker-compose.yml
- deploy/monitoring/nixos/iscy-monitoring.nix
- deploy/monitoring/nixos/example-host.nix

Die Statusseite /status/ zeigt neben Health, Migrationen, Modulen, offenen Signalen und Prometheus-Scrape-Konfiguration auch einen kompakten Grafana-Query-Spickzettel sowie direkte Links zu Incident-Fallakten und /operations/incidents/. Das Grafana-Dashboard enthaelt zusaetzlich Panels fuer Alert-Incidents mit konfigurierbarer iscybaseurl, konkretem Incident-Drilldown ueber iscyoperationsalertmanagerincidentinfo, Product-Security-Coverage, CVE-Review-Trend und Importvalidierung.

Der Product-Security-Bereich zeigt zusaetzlich Trenddaten fuer SBOM-/CSAF-/Threat-Coverage, offene CVE-Reviews, fehlende Evidence, Importvalidierung, Snapshot-Verlauf, CRA-Readiness und SBOM-Diffs. Maschinenlesbar sind diese Daten ueber GET /api/v1/product-security/trends, GET /api/v1/product-security/products/{productid}/cra-readiness, GET /api/v1/product-security/sbom-diff und ueber Prometheus-Metriken wie iscyproductsecuritytrendsignal, iscyproductsecuritycoveragepercent und iscyproductsecurityimportvalidationtotal.

Runbook fuer automatisch erzeugte Alert-Incidents:

1. Neue Fallakte in /operations/incidents/ sichten, bei Bedarf nach open, critical oder resolved filtern und in /incidents/ oeffnen.
2. Severity, Scope und betroffene Services pruefen.
3. Automatische Evidence kontrollieren und bei Bedarf Grafana-/Log-Nachweise nachreichen.
4. Owner, Eindaeummung, Kommunikation, NIS2-Erheblichkeit und weitere regulatorische Relevanz bewerten.
5. Nach Behebung Timeline, Root Cause, Lessons Learned und Alert-Schwelle reviewen.

Wichtige lokale Pruefbefehle:

```
nix develop --command make rust-smoke
nix develop --command make rust-restore-smoke
ISCY_POSTGRES_RESTORE_DRILL_SOURCE_URL=postgresql://isms:<password>@localhost:5432/iscy_drill_source
\
ISCY_POSTGRES_RESTORE_DRILL_RESTORE_URL=postgresql://isms:<password>@localhost:5432/iscy_drill_restore
\
nix develop --command make rust-postgres-restore-drill
nix develop --command make team-test
make rust-test
make rust-smoke
make team-test
nix flake check
```

rust-restore-smoke erzeugt ueber die laufende Rust-API einen Evidence-Upload, restauriert SQLite-Datenbank und Media-Verzeichnis und prueft danach die DB-Dateireferenz sowie die unveraenderte SHA-256-Pruefsumme. Damit wird nicht nur die Existenz irgendeiner Datei, sondern

die Integritaet eines zusammengehoerigen Evidence-Artefakts getestet.

Agent-Payload lokal testen:

```
nix run .#iscy-agent -- --self-test
```

Im Browser kann ein Administrator danach /zero-trust/ oeffnen und Agent hinzufuegen waehlen. Der Assistent erzeugt das Token erst nach der Zusammenfassung und zeigt es genau einmal in einer nicht cachebaren Installationsansicht. Unter /zero-trust/ bleiben anschliessend nur sichere Metadaten, Lifecycle, Policy-Zuordnung, letzter Versuch und Flottenstatus sichtbar.

Agent an eine lokale ISCY-Instanz melden lassen:

```
ISCY_BACKEND_URL=http://127.0.0.1:9000 \  
ISCY_TENANT_ID=1 \  
ISCY_USER_ID=1 \  
nix run .#iscy-agent
```

Produktive Agenten sollten mit Enrollment-Token aufgenommen werden:

```
ISCY_BACKEND_URL=http://127.0.0.1:9000 \  
ISCY_TENANT_ID=1 \  
ISCY_AGENT_ENROLLMENT_TOKEN=<token> \  
nix run .#iscy-agent
```

Danach nutzt der Agent automatisch seinen lokalen State. Fertige Betriebsbeispiele fuer systemd, NixOS, Windows Scheduled Tasks und macOS LaunchDaemons liegen unter `deploy/agent/`; Details stehen in `docs/ZEROTRUSTAGENT.md`.

Merksatz: Erst ISCY starten, dann den Agent per `--self-test` pruefen, einmalig mit Token enrollen und anschliessend ohne Token periodisch betreiben.

6.7 Docker-Betrieb in einfacher Sprache:

Wenn du ISCY schnell und reproduzierbar starten willst, nutze Docker.

1. make docker-check

Prueft zuerst alle Compose-Dateien auf Syntax und Zusammenbau.

2. make docker-smoke

Startet eine kurze Rust-Funktionsprobe (DB, Healthcheck und zentrale API-Probes) und faehrt danach wieder herunter.

3. Danach den gewuenschten Modus starten

- lokal: make dev-up
- stage: make stage-up
- produktiv: make prod-up oder make prod-up-llm

Merksatz: Erst validieren, dann kurz testen, dann dauerhaft starten.

6.8 CRA, IoT/Cloud, Windows, OT und Produktionsarchitektur (einfach erklart):

Stand dieser Anleitung: 18. April 2026.

CRA (Cyber Resilience Act) in kurz

- Der CRA ist seit Dezember 2024 in Kraft.
- Meldepflichten starten ab 11. September 2026.
- Die wesentlichen Pflichten gelten ab 11. Dezember 2027.

Fuer ISCY bedeutet das praktisch:

1. Produkt-Scope und Komponenten sauber pflegen.
2. Schwachstellen- und Patch-Prozess dokumentieren.
3. Incident- und Meldewege frueh vorbereiten.
4. Nachweise (Evidenz) revisionsfest ablegen.

IoT- und Cloud-Security in kurz

- IoT: Asset-Inventar, sichere Defaults, Updatefaehigkeit, Segmentierung.
- Cloud: Identitaeten haerten, Logs zentral sammeln, Konfigurationen regelmaessig pruefen.
- In ISCY: Prozesse, Assets, Risiken und Massnahmen zusammenfuehren.

Windows-Hardening in kurz

- Admin-Rechte minimieren.
- MFA, starke Authentisierung und Session-Kontrollen aktivieren.
- Security-Baselines und Patch-Stand regelmässig prüfen.
- Ueber ISCY als Prozess + Evidenz + Review dokumentieren.

OT-Security und Produktionssysteme (OPC UA, MES, SCADA, IdentPro)

- IT und OT klar trennen (Zonen/Segmente).
- Fernzugriffe streng kontrollieren.
- Kritische Schnittstellen (z. B. OPC UA, MES, SCADA, Identitätsprovider) inventarisieren.
- Notfall- und Wiederanlaufabläufe fuer Produktion ueben.
- In ISCY als Risiko, Massnahme, Evidenz und Incident-Playbook abbilden.

Merksatz: Technik, Organisation und Nachweis muessen zusammenpassen.

6.9 Einfache Abnahme-Checkliste fuer die neuen Themen:

Nutze diese Liste als schnelle Team-Abnahme in ISCY:

1. Docker laeuft stabil
 - make docker-check ist ohne Fehler durchgelaufen.
 - make docker-smoke ist ohne Fehler durchgelaufen.
2. CRA-Readiness sichtbar
 - Product-Security-Scope ist gepflegt.
 - SBOM-Diff und VEX-Entscheidungen sind fuer relevante Releases dokumentiert.
 - Schwachstellen-/Patch-Prozess ist dokumentiert.
 - Incident-/Meldeweg ist dokumentiert.
3. Cloud-Security umgesetzt
 - Cloud-Services sind inventarisiert.
 - Cloud-Identitäten/Schlüssel folgen Least-Privilege.
4. Windows-Hardening umgesetzt
 - Baselines sind definiert.
 - lokale Adminrechte, Makros, SMB und Firewall sind geregelt.
5. OT-/Produktions-Security umgesetzt
 - Zonen/Conduits sind dokumentiert.
 - OPC UA, MES, SCADA und Produktions-Identitäten sind abgesichert.
6. Nachweise vorhanden
 - Zu jedem Punkt gibt es in ISCY mindestens Prozess, Risiko oder Massnahme plus Evidenz.

Merksatz: Nicht nur planen - auch nachweisbar umsetzen.

6.10 Zero-Trust-Ausbaupfad:

Grundschutz wird in diesem Arbeitsstand bewusst zurueckgestellt. Der sinnvolle naechste Fokus fuer ISCY ist Zero Trust als laufende technische Posture-Sicht.

Was aktuell belastbar vorhanden ist:

- Rust-only Backend mit Zero-Trust-Webansicht unter /zero-trust/
- read-only Agent fuer Windows, macOS und Linux
- Enrollment-Token, Agent-Secret und optionale mTLS-Fingerprint-Bindung
- gefuehrter Admin-Assistent mit einmaliger, nicht cachebarer Installationsansicht
- auditierbarer Token-Lifecycle mit begrenzter Parallelverwendung und Widerruf
- persistenter Agent-State und begrenzte Offline-Queue
- administrative Agent-Secret-Rotation
- systemd-, NixOS-, Windows- und macOS-Betriebsbeispiele
- Inventar, Heartbeat und lokale OS-/MDM-/EDR-Findings
- Scores nach Device und Pillar
- offene Findings nach Severity
- Fokuskarte fuer den naechsten fachlich sinnvollen Schritt
- Flottensignale in Statusseite, JSON und Prometheus
- editierbare Agent-Policy-Profile und erwartete Coverage nach fachlichem Scope
- sichere Notification-Kanaele mit Cooldown, Delivery-Audit und periodischem Worker
- gemeinsame fachuebergreifende Notifications fuer Agent/Fleet, Evidence, Product Security/CVE, Incidents und Roadmap

Was als naechstes fachlich am meisten bringt:

1. Findings mit Risiken und Evidenzen verbinden
- Aus wiederkehrenden High-/Critical-Findings sollten Risiken, Massnahmen und

Evidenzanforderungen ableitbar sein.

2. MDM-/EDR-Integrationen vorbereiten

Intune, Jamf, Microsoft Defender, Wazuh, CrowdStrike oder SentinelOne sollten zunächst als Import-/Connector-Schicht angebunden werden, nicht als Fernsteuerung.

3. Softwareinventar und CVE-Korrelation ergänzen

Agent- oder MDM-Inventar sollte mit dem CVE-Bereich verbunden werden, damit betroffene Systeme schneller sichtbar sind.

4. Ausnahme- und Ablaufdatum erzwingen

Akzeptierte Abweichungen sollten Owner, Begründung, Laufzeit und Wiedervorlage haben.

5. Signierte Agent-Pakete bauen

Die Service-Beispiele sind vorhanden; als nächster Schritt folgen Windows MSI/Intune-Paket, macOS PKG/Jamf-Profil und signierte Linux-Pakete.

6. CA-/PKI-Anbindung separat planen

Private Schlüssel und CSR sollen lokal auf dem Agent entstehen; Ausstellung, Rotation und Widerruf gehören in einen eigenen, providerunabhängigen Meilenstein.

7. Remediation getrennt halten

Automatische Änderungen am Endgerät sollten erst später als signierter, auditierbarer Policy-Schritt kommen.

Fachliches Kurzrteil:

ISCY ist für Zero Trust jetzt gut positioniert. Sollabdeckung, aktive

Policy-Benachrichtigungen und geführtes Onboarding sind vorhanden; die nächste Reife entsteht durch Nachweisverknüpfung, Connectoren und sauber signierte Deployment-Pakete.

6.11 Fachübergreifende Notifications:

ISCY erweitert den vorhandenen Agent-Notification-Kanalbetrieb, statt eine zweite Notification-Engine einzuführen. Dieselben Webhook-Kanäle, Production-Allowlist, Redirect-Sperre, Bearer-/HMAC-Secret-Referenzen, Retry-Grenzen, Cooldowns, der periodische Worker und die manuelle Auswertung verarbeiten jetzt auch:

- abgelaufene und innerhalb von 30 Tagen ablaufende Evidence
- Evidence ohne Review, Retention oder SHA-256 bei vorhandenem Dateiobjekt
- offene und überfällige CVE-Reviews, kritische offene CVEs sowie offene CVE-Korrelationsreviews
- offene Nicht-Meldeentscheidungen und fehlende Begründungen bei Incidents
- heute fällige, überfällige, blockierte oder kritische offene Roadmap-Tasks

Die Auswertung nutzt ausschließlich vorhandene fachliche Status-, Review-, Severity- und Fälligkeitsfelder. Eine überfällige Incident-Review-Frist wird nicht erfunden, weil dafür derzeit kein eigenes fachliches Fristfeld existiert.

Ein stabiler Signal-Key kombiniert Tenant, Domäne, Objekttyp, Objekt-ID, Signaltyp und Zustands- oder Fälligkeitskontext. Nach einem Zustellversuch gilt der Cooldown des Kanals auch bei einem Fehler; interne Retry-Versuche bleiben auf den bestehenden kleinen Satz transienter Netzwerk- und HTTP-Fehler begrenzt. Migration 0029rustcrossdomainnotifications ergänzt bestehende Delivery-Zeilen additiv um Domäne, Objektbezug, Signaltyp, sichere Fehlerklasse, letzten Versuch und nächsten möglichen Zustellzeitpunkt.

Webhook-Payloads enthalten nur Tenant, Domäne, Objekttyp/-ID, Signaltyp, Schweregrad, Status und optionalen Fälligkeitskontext. Token, Bearer-/HMAC-Secrets, Authorization Header, personenbezogene Details, vertrauliche Objekttexte, vollständige Fachpayloads und interne Fehler werden weder in Responses noch in der Read-only-Ansicht ausgegeben. Administratoren dürfen Kanäle und Signaltypen ändern; authentifizierte Read-only-Rollen sehen nur sichere tenantgebundene Delivery-Metadaten.

Bewusst nicht umgesetzt sind Evidence-Legal-Hold und -Disposition, kontrollierte Löschung, Re-Hash-Worker, Objektspeicher, CA-/PKI-/CSR-Funktionen, signierte Agent-Pakete, Release-Provenance sowie Performance-, HA- und visuelle Regressionserweiterungen.

7. Was die wichtigsten Begriffe bedeuten:

- ISO 27001: internationaler Standard für Informationssicherheits-Managementsysteme
- ISMS: Managementsystem für Informationssicherheit
- NIS2: EU-Regelwerk für Cybersecurity-Pflichten wesentlicher und wichtiger Einrichtungen
- KRITIS: Kritische Infrastrukturen
- SoA: Statement of Applicability, also die begründete Auswahl und Bewertung von Controls
- Audit: systematische Prüfung

- Finding: Feststellung aus einer Pruefung
- Evidence: Nachweis
- CVE: standardisierte Kennung fuer eine bekannte Schwachstelle
- CVSS: Basisscore fuer technische Schwere
- EPSS: Wahrscheinlichkeitsmodell fuer die Ausnutzung einer Schwachstelle
- KEV: Liste bekannter aktiv ausgenutzter Schwachstellen
- TARA: Threat Analysis and Risk Assessment
- PSIRT: Product Security Incident Response Team

8. Was ISCY ausdruecklich nicht ersetzt:

ISCY ersetzt nicht:

- eine Rechtsberatung
- eine vollautomatische Sicherheitsbewertung ohne Fachpruefung
- operative Patch- oder Deployment-Tools
- ein SIEM oder SOC
- ein vollwertiges Projektmanagement-Werkzeug fuer alle Unternehmensbereiche

ISCY strukturiert, dokumentiert, priorisiert und verbindet. Entscheidungen muessen trotzdem fachlich verantwortet werden.

9. Empfehlungen fuer die Einfuehrung:

- mit einem Tenant und einem realen Scope starten
- lieber wenige, aber belastbare Daten pflegen
- Begriffe intern vereinheitlichen
- Nachweise frueh sammeln
- Risiken nicht technisch, sondern geschaeftlich formulieren
- Produkt- und Schwachstellenlogik nur dort aktivieren, wo sie wirklich gebraucht wird

10. Strategische Weiterentwicklung:

Die Rust-Migration ist abgeschlossen. Mit V23.7.19 ist das regulatorische Organisationsprofil als erster strategischer Baustein umgesetzt; V23.7.20 ergaenzt Management-Review- und Audit-Pakete als steuerbaren Review-Workflow; V23.7.21 liefert Exporte, Snapshot-Ruecklinks und Evidence-Qualitaet; V23.7.22 setzt Third-Party-/Supplier-Risk als eigenes Rust-Web-/API-Modul um; V23.7.23 baut Product Security um VEX, SBOM-Diff und CRA-Readiness aus; V23.7.24 fuegt AI Governance hinzu; V23.7.25 schliesst Agent-Policy-Profile, erwartete Flottenabdeckung und aktive Policy-Webhooks an; V23.7.26 ergaenzt versionierte Product-Security-Evidence-Pakete. Migration 0027rustaigovernancelinks verbindet AI-Systeme tenantgebunden mit Risiken, Roadmap-Tasks, Incidents und Changes. Migration 0028rustguidedagentonboarding ergaenzt den gefuehrten, tenantgebundenen Agent-Rollout mit Token-Lifecycle, Policy-Zuordnung und Auditspur. Migration 0029rustcrossdomainnotifications fuehrt Evidence-, CVE-, Incident- und Roadmap-Signale in denselben sicheren Kanalbetrieb. Migration 0031rustsupplierreviewworkflow ergaenzt Supplier-Reviews mit Freigabehistorie, Subprocessors, Vertragslaufzeiten, Exit-Test-Nachweisen und tenantgesicherten Evidence-/Control-/Risk-Links. Migration 0032rustmanagementregulatorytemplates ergaenzt Management-/Regulatory-Templates fuer ISO 27001, NIS2, DORA, KRITIS und generische Security-Governance-Reviews. Die weitere ISCY-Agenda konzentriert sich deshalb nicht mehr auf Abloesung alter Python-/Django-Pfade, sondern auf fachliche Produktreife.

Die priorisierte Roadmap liegt in docs/ISCYSTRATEGICROADMAP.md und umfasst:

1. Feinere Management-/Regulatory-Template-Varianten und kontextsensitive Pruefpakete
2. Evidence-Disposition, periodische Re-Hash-Pruefung und optionales Objektspeicher-Backend
3. Signierte Agent-Pakete sowie eine spaetere getrennte CA-/PKI-Stufe
4. Performance-, HA- und visuelle Regressionstests

Der Leitgedanke bleibt: ISCY soll keine Regulierungen als Silos verwalten, sondern Organisation, Assets, Suppliers, Produkte, Controls, Risiken, Evidence, Incidents, Product Security, AI Governance, Agent-Posture und Roadmap-Arbeit in einem gemeinsamen Steuerungsmodell verbinden.

11. Git-Bezug dieses Handbuchs:

Dieses Handbuch ist bewusst als Markdown-Datei im Repository abgelegt, damit es:

- versioniert werden kann
- mit dem Produkt mitwaechst
- in Pull Requests geprueft werden kann

Das PDF-Handbuch docs/ISCYHandbuch.pdf wird reproduzierbar aus Markdown erzeugt:

make docs-pdf